

FinWallet Fraud Path - Allow, Review, Deny and Fail-Closed

This document shows the actual fraud-control order in FinWallet v1. In the current implementation fraud runs before WalletTransfer and Purchase. The BankDeposit happy path does not call the fraud service.

0. Preconditions

The example assumes two active customers with two TRY wallets. The source wallet was previously funded through BankDeposit.

```
{{gateway}} = http://localhost:8080
{{tokenA}} = source customer JWT
{{sourceWalletId}} = Customer A TRY wallet
{{destinationWalletId}} = Customer B TRY wallet
{{internalKey}} = Gateway InternalServiceKey
```

1. CLIENT - Fraud-protected WalletTransfer request

Normal low-risk example:

```
POST {{gateway}}/api/v1/transfers
Authorization: Bearer {{tokenA}}
Idempotency-Key: fraud-allow-demo-001
Content-Type: application/json
X-Correlation-Id: fraud-allow-001

{
  "sourceWalletId": "11111111-aaaa-aaaa-aaaa-111111111111",
  "destinationWalletId": "22222222-bbbb-bbbb-bbbb-222222222222",
  "amount": 500.00
}
```

The client never supplies trust/risk flags. Country, device, velocity, 24-hour aggregate, beneficiary history and currency are derived server-side.

2. Replay check runs before fraud

If the same request with the same Idempotency-Key already completed, FinWallet returns the stored result without calling the fraud provider again.

```
Completed replay -> same transactionId -> no second money movement -> no second fraud
evaluation
```

Reusing the same key with a different amount/destination returns 409 IDEMPOTENCY_CONFLICT.

3. Server-side risk-signal read

FinWallet derives the following from MSSQL:

```
Is the customer/session still active?
Does the customer own the source wallet?
Are source and destination wallets Active?
What is the currency?
Is the device new for this customer?
How many successful transfers occurred in 5 minutes?
What is the 24-hour same-currency amount?
Is the destination a known beneficiary?
What is the CountryCode?
```

Raw DeviceId is not sent to the external provider; an opaque/hash device reference is used.

4. Internal Fraud Engine

Active rules:

```
TransactionAmountFraudRule
```

DailyAmountFraudRule
VelocityFraudRule
NewDeviceBeneficiaryFraudRule

Decision priority:

Deny > Review > Allow

TRY single-transaction example thresholds:

< 20,000 TRY -> amount rule Allow
>= 20,000 TRY -> amount rule Review
>= 75,000 TRY -> amount rule Deny

When internal fraud returns Deny, FakeFraud is not called because an external Allow can never override an internal Deny.

5A. FRAUD ALLOW PATH

With 500 TRY and normal device/velocity signals, the internal result may be Allow. When it is not Deny, FinWallet calls FakeFraud.

INTERNAL - FakeFraud evaluate

POST {{gateway}}/providers/fraud/api/v1/fraud/evaluate
X-Internal-Service-Key: {{internalKey}}
Content-Type: application/json
X-Correlation-Id: fraud-allow-001

Example PII-free request:

```
{
  "transactionReference": "33333333-3333-3333-3333-333333333333",
  "customerReference": "44444444-4444-4444-4444-444444444444",
  "transactionType": "WalletTransfer",
  "amount": 500.00,
  "currency": "TRY",
  "countryCode": "TR",
  "deviceReference": "A9C8D7E6F5...",
  "isNewDevice": false,
  "transactionCountLastFiveMinutes": 0,
  "amountLastTwentyFourHours": 0.00,
  "merchantId": null
}
```

FakeFraud response:

```
{
  "isSuccess": true,
  "code": "FRAUD_EVALUATED",
  "message": "External fraud evaluation completed.",
  "data": {
    "providerReference": "55555555-5555-5555-5555-555555555555",
    "decision": 1,
    "riskScore": 0,
    "reasonCodes": ["NO_EXTERNAL_RISK_SIGNAL"]
  },
  "errors": []
}
```

decision=1 means Allow.

FinWallet combined policy:

Internal Allow + External Allow = Final Allow

A durable FraudEvent is stored and atomic transfer posting starts.

CLIENT success response

```
{
  "isSuccess": true,
  "code": "WALLET_TRANSFER_COMPLETED",
  "message": "Wallet transfer completed successfully.",
}
```

```

"data": {
  "transactionId": "66666666-6666-6666-6666-666666666666",
  "sourceWalletId": "11111111-aaaa-aaaa-aaaa-111111111111",
  "destinationWalletId": "22222222-bbbb-bbbb-bbbb-222222222222",
  "amount": 500.00,
  "currency": "TRY",
  "completedAt": "2026-08-10T20:30:00+00:00",
  "wasReplay": false
},
"errors": []
}

```

Atomic ledger:

```

Debit   source Wallet Liability    500 TRY
Credit destination Wallet Liability 500 TRY

```

5B. FRAUD REVIEW PATH

Example request: 25,000 TRY.

The internal TRY single-transaction rule starts Review at 20,000, and FakeFraud starts Review at 25,000.

```

POST {{gateway}}/api/v1/transfers
Authorization: Bearer {{tokenA}}
Idempotency-Key: fraud-review-demo-001
Content-Type: application/json

{
  "sourceWalletId": "11111111-aaaa-aaaa-aaaa-111111111111",
  "destinationWalletId": "22222222-bbbb-bbbb-bbbb-222222222222",
  "amount": 25000.00
}

```

Combined decision:

Internal Review + External Review = Final Review

The FraudEvent is durably stored in Pending review state. No money movement or ledger posting occurs.

Public response:

```

{
  "isSuccess": false,
  "code": "TRANSFER_REVIEW_REQUIRED",
  "message": "The transfer requires additional review and no money was moved.",
  "data": null,
  "errors": []
}

```

HTTP status: 202 Accepted.

INTERNAL - List pending fraud reviews

```

GET {{gateway}}/api/v1/internal/fraud-reviews?take=50
X-Internal-Service-Key: {{internalKey}}

```

The pending FraudEvent exposes internal/external/final decisions and reason codes, but not request hashes, tokens or PII.

INTERNAL - Approve review

```

POST {{gateway}}/api/v1/internal/fraud-reviews/{{fraudEventId}}/decision
X-Internal-Service-Key: {{internalKey}}
X-Reviewer-Id: ops-reviewer-01
Content-Type: application/json

{
  "approve": true
}

```

Success code:

FRAUD_REVIEW_APPROVED

The customer resubmits the same transfer with the same Idempotency-Key. The handler finds the durable FraudEvent, does not call external fraud again and continues to atomic posting because the review is Approved.

5C. FRAUD DENY PATH

Example request: 100,000 TRY.

The internal TRY deny threshold is 75,000 TRY, therefore the internal engine immediately returns Deny and FakeFraud is not called.

```
POST {{gateway}}/api/v1/transfers
Authorization: Bearer {{tokenA}}
Idempotency-Key: fraud-deny-demo-001
Content-Type: application/json

{
  "sourceWalletId": "11111111-aaaa-aaaa-aaaa-111111111111",
  "destinationWalletId": "22222222-bbbb-bbbb-bbbb-222222222222",
  "amount": 100000.00
}
```

Response:

```
{
  "isSuccess": false,
  "code": "TRANSFER_FRAUD_DENIED",
  "message": "The transfer was denied by fraud controls.",
  "data": null,
  "errors": []
}
```

HTTP status: 403 Forbidden.

A durable FraudEvent remains for audit; Wallet and Ledger do not change.

5D. FRAUD PROVIDER UNAVAILABLE - FAIL CLOSED

If internal fraud is not Deny, FakeFraud is required. A timeout, network failure or invalid provider response prevents financial posting.

Public response:

```
{
  "isSuccess": false,
  "code": "FRAUD_DEPENDENCY_UNAVAILABLE",
  "message": "The required fraud service is temporarily unavailable.",
  "data": null,
  "errors": []
}
```

HTTP status: 503 Service Unavailable.

Fail-closed rule:

Uncertain fraud dependency -> no money movement -> no ledger posting

6. Decision matrix

Internal	External	Final behavior
Allow	Allow	Allow -> atomic posting
Review	Allow	Review -> 202, no money movement
Allow	Review	Review -> 202, no money movement
Review	Review	Review -> 202, no money movement
Deny	Not called	Deny -> 403
Allow/Review	Provider unavailable	503 fail-closed

7. Example fraud reason codes

INTERNAL_NO_RISK_SIGNAL
INTERNAL_HIGH_TRANSACTION_AMOUNT
INTERNAL_VERY_HIGH_TRANSACTION_AMOUNT
NO_EXTERNAL_RISK_SIGNAL
HIGH_TRANSACTION_AMOUNT
VERY_HIGH_TRANSACTION_AMOUNT
ELEVATED_VELOCITY_5M
HIGH_VELOCITY_5M
ELEVATED_24H_AMOUNT
HIGH_24H_AMOUNT
NEW_DEVICE_HIGH_AMOUNT
BLOCKED_MERCHANT
HIGH_RISK_COUNTRY